Light

Cyber Security — Threats

Over **1,100,000+ marks** of exam-aligned content across **67 qualifications**. 4,200+ auto-marked assessments & long-answer practice. No login required.

Assessment Hub | Notes / Textbook | Long-Answer Practice

Assessment Hub
Long-Answer
Notes Index
What you must know
Toolkit
1. Types of malware
2. Social engineering & vulnerabilities
3. Protection methods
Worked examples
Quick reference
Typical pitfalls

Edexcel GCSE Computer Science — **Cyber Security Threats (1CP2/01 Topic 5: Issues and Impact)**. This topic covers the different types of malware, social engineering attacks, technical vulnerabilities, and the methods used to protect computer systems and data from cyber threats.

Exam questions typically ask you to **define** types of malware, **describe** how attacks work, **explain** protection methods, and **discuss** the impact of cyber threats on individuals and organisations. The 2024 Paper 1 included a flowchart question on how antivirus software detects and removes malware. Expect questions worth 2—6 marks requiring you to link threats to appropriate protections.

Why cyber security matters

Cyber security is one of the most important issues in modern computing:

- **Real-world relevance:** Cyber attacks affect millions of people every year, from individuals losing personal data to businesses suffering major financial losses
- **Growing threat:** As more of our lives move online, the opportunities for criminals to exploit vulnerabilities increase
- **Career importance:** Cyber security is one of the fastest-growing career areas in technology

- **Personal responsibility:** Understanding threats helps you protect your own data and devices
- **Exam relevance:** This topic appears in Paper 1 as part of Topic 5, typically worth 4—8 marks across multiple sub-questions

What you must know

This checklist covers the key exam-visible concepts from Edexcel 1CP2 Topic 5: Issues and Impact. You should be able to explain each point and apply it to exam scenarios.

- **Define** the term malware and **describe** the characteristics of different types: viruses, worms, Trojans, ransomware, and keyloggers
- **Explain** how each type of malware spreads and what damage it causes
- **Describe** social engineering attacks including phishing, pretexting, baiting, and shoulder surfing
- **Identify** technical vulnerabilities that attackers exploit, such as unpatched software and weak passwords
- **Explain** protection methods including anti-malware software, encryption, backups, and acceptable use policies (AUPs)
- **Discuss** the impact of cyber attacks on individuals and organisations

> **Specification link:** This topic covers Edexcel 1CP2 Paper 1 Topic 5: Issues and Impact — specifically cybersecurity threats (malware types, technical vulnerabilities, social engineering) and protection methods (anti-malware, encryption, AUPs, backup).

Toolkit

These are the key patterns, definitions and relationships you need to apply in exam questions.

Malware types at a glance

Malware type	Key characteristic	How it spreads	Main damage
Virus	Attaches to legitimate files; requires user action to spread	Email attachments, downloads, infected USB drives	Corrupts/deletes files, slows system
Worm	Self-replicating; spreads automatically without user action	Networks, exploiting vulnerabilities	Consumes bandwidth, crashes networks
Trojan	Disguised as legitimate software; does not self-replicate	Downloaded by user thinking it is useful software	Creates backdoor, steals data
Ransomware	Encrypts user's files; demands payment for decryption key	Phishing emails, malicious downloads	Files inaccessible, financial loss

Malware type	Key characteristic	How it spreads	Main damage
Keylogger	Records keystrokes to capture sensitive information	Hidden in other malware or installed physically	Steals passwords, credit card numbers

Social engineering attacks

Attack type	Method	Example
Phishing	Fraudulent emails/websites trick users into revealing sensitive information	Email appearing to be from a bank asking user to "verify" login details
Pretexting	Attacker invents a scenario to obtain information or access	Caller pretends to be IT support asking for password to "fix" an issue
Baiting	Tempting victim with something desirable (often infected media)	USB drive labelled "Payroll" left in car park, hoping someone plugs it in
Shoulder surfing	Observing someone entering sensitive information	Watching someone enter their PIN at a cash machine

Protection methods summary

Protection	What it does	Protects against
Anti-malware software	Scans files for known malware signatures; quarantines/removes threats	Viruses, worms, Trojans, ransomware, keyloggers
Encryption	Converts data into unreadable format; requires key to decrypt	Data theft, interception during transmission
Backup	Creates copies of data stored separately from original	Ransomware, accidental deletion, hardware failure
Acceptable Use Policy (AUP)	Rules defining how systems and data should be used	Insider threats, accidental breaches, social engineering
Software updates/patches	Fixes known vulnerabilities in software	Exploits targeting unpatched systems
Strong passwords	Complex credentials difficult to guess or crack	Brute force attacks, dictionary attacks

Key definitions

Malware: Malicious software designed to damage, disrupt, or gain unauthorised access to a computer system.
Social engineering: Manipulating people into revealing confidential information or performing actions that compromise security.
Vulnerability: A weakness in a system that can be exploited by attackers to gain unauthorised access or cause damage.
Encryption: The process of converting data into a coded format that can only be read with the correct decryption key.

1. Types of malware

Malware is short for "malicious software" — any software intentionally designed to cause damage to a computer, server, network, or user. Understanding the different types of malware is essential for recognising threats and applying appropriate protection.

1.1 Viruses

A **virus** is malware that attaches itself to a legitimate program or file. When the infected file is opened or executed, the virus activates and can spread to other files on the same system.

Key characteristics of viruses:

- Requires a **host file** — cannot exist independently
- Requires **user action** to spread (opening an attachment, running a program)
- Can remain dormant until triggered by a specific event
- Spreads via email attachments, downloads, USB drives, and file sharing

Typical damage:

- Corrupting or deleting files
- Slowing down system performance
- Displaying unwanted messages or adverts
- Crashing the operating system

1.2 Worms

A **worm** is malware that can replicate itself and spread across networks **without needing a host file** or user action. Worms exploit vulnerabilities in operating systems or network protocols to spread automatically.

Key difference from viruses:

- Worms are **self-replicating** — they do not need to attach to another program
- Worms spread **automatically** over networks without user intervention
- Worms often spread much faster than viruses because no user action is required

Typical damage:

- Consuming network bandwidth, slowing networks to a crawl
- Overloading servers and causing system crashes
- Creating backdoors for other malware
- Deleting or modifying files

> **Exam tip:** The key difference between a virus and a worm is how they spread. Viruses need a host file and user action; worms are self-replicating and spread automatically. This is a common exam comparison question.

1.3 Trojans

A **Trojan** (or Trojan horse) is malware disguised as legitimate software. The name comes from the Greek myth where soldiers hid inside a wooden horse to enter the city of Troy.

Key characteristics of Trojans:

- Appears to be useful or desirable software
- User **willingly downloads and installs** it, not knowing it is malicious
- Does **not self-replicate** — relies on social engineering to spread
- Often creates a "backdoor" allowing attackers remote access

Typical damage:

- Stealing personal data (passwords, banking details)
- Allowing remote control of the computer
- Installing additional malware
- Recording user activity

1.4 Ransomware

Ransomware is malware that encrypts the victim's files and demands payment (a ransom) for the decryption key. This type of attack has become increasingly common and can be devastating for individuals and organisations.

How ransomware works:

- Malware infects the system (often via phishing email or malicious download)
- Files are encrypted so the user cannot access them
- A ransom demand is displayed, often requesting payment in cryptocurrency
- Victim must pay to receive the decryption key (though payment does not guarantee recovery)

Impact:

- Loss of access to important files and data
- Financial loss from paying ransom or lost business
- Reputational damage for organisations
- Time and cost of recovery

1.5 Keyloggers

A **keylogger** is software or hardware that records every keystroke made on a computer. This allows attackers to capture sensitive information such as passwords, credit card numbers, and private messages.

Types of keyloggers:

- **Software keyloggers:** Programs installed on the computer (often hidden within other malware)
- **Hardware keyloggers:** Physical devices connected between the keyboard and computer

What keyloggers capture:

- Usernames and passwords
- Credit card and bank account details
- Private messages and emails
- Search queries and browsing activity

How keyloggers are installed:

- Hidden inside Trojans or other malware downloaded by the user
- Installed by someone with physical access to the computer
- Delivered through phishing emails with malicious attachments

- Hardware keyloggers physically plugged into the computer without the user's knowledge

1.6 Impact of malware attacks

Malware attacks can have serious consequences for individuals and organisations. Understanding these impacts helps explain why cyber security is so important.

Impact on individuals

- **Financial loss:** Money stolen from bank accounts, fraudulent purchases, ransom payments
- **Identity theft:** Personal details used to commit fraud or open accounts in victim's name
- **Data loss:** Personal files, photos, and documents corrupted or deleted
- **Privacy invasion:** Personal communications and activities monitored
- **Time and stress:** Hours spent recovering accounts and fixing infected devices

Impact on organisations

- **Financial loss:** Ransom payments, lost business, recovery costs, fines for data breaches
- **Reputational damage:** Loss of customer trust after a publicised breach
- **Operational disruption:** Systems down, employees unable to work, services unavailable
- **Legal consequences:** Fines for failing to protect personal data (Data Protection Act)
- **Competitive harm:** Trade secrets or intellectual property stolen by competitors

1.7 Malware comparison diagram

```
┌──────────────────────────────────────────────────────────────────────────────────────────────────────────────┐
│ TYPES OF MALWARE │
├──────────────────────────────────────────────────────────────────────────────────────────────────────────────┤
│ │ VIRUS WORM TROJAN │ │ ┌──────────────┐ ┌──────────────┐ ┌──────────────┐ │ │
│ Attaches │ │ Self- │ │ Disguised │ │ │ │ to host │ │ replicating│ │ as
legit │ │ │ │ file │ │ │ │ software │ │ │ │ │ │ Spreads │ │ │ │ │ │ Needs
user │ │ auto- │ │ User │ │ │ │ action │ │ matically │ │ installs │ │ │
└──────────────┘ └──────────────┘ └──────────────┘ │ │ │ │ │ │ ▼ ▼ ▼ │ │
Corrupts files Clogs networks Creates backdoor │ │ │ │ RANSOMWARE KEYLOGGER
│ │ ┌──────────────┐ ┌──────────────┐ │ │ │ Encrypts │ │ Records │ │ │ │ user
files │ │ keystrokes │ │ │ │ │ │ │ │ │ │ Demands │ │ Captures │ │ │ │ │
payment │ │ passwords │ │ │ └──────────────┘ └──────────────┘ │ │ │ │ │ │ ▼ ▼ │
│ Financial loss Identity theft │ │ │
└──────────────────────────────────────────────────────────────────────────────────────────────────────────────┘
```

Worked Example 1 — Defining malware

Question: Define the term 'malware'. [1 mark]

Model answer:

Malware is malicious software **(1)** designed to damage, disrupt, or gain unauthorised access to a computer system.

Exam tip: The word "malware" is a combination of "malicious" and "software". Always include both elements: (1) it is software, (2) it is harmful/malicious.

Worked Example 2 — Identifying malware types

Question: State two types of malware. [2 marks]

Model answer:
Virus **(1)**
Ransomware **(1)**

Exam tip: Choose different types. Do not give variations of the same type. Valid answers include: virus, worm, Trojan, ransomware, keylogger.

Worked Example 3 — Describing how a virus spreads

Question: Describe how a computer virus spreads. [2 marks]

Model answer:
A virus attaches itself to a legitimate file or program **(1)**.
When the user opens/runs the infected file, the virus activates and can spread to other files **(1)**.

Exam tip: The key point is that viruses need **user action** — they do not spread automatically like worms. Always mention the host file and the trigger (user opening/running it).

Worked Example 4 — Comparing virus and worm

Question: State one difference between a virus and a worm. [2 marks]

Model answer:
A virus requires user action to spread / needs a host file **(1)**, whereas a worm spreads automatically / is self-replicating / does not need a host file **(1)**.

> **Exam tip:** For comparison questions, you must state both sides of the comparison to get full marks. Use linking words like "whereas", "but", or "however".

2. Social engineering and vulnerabilities

Not all cyber attacks rely on technical exploits. **Social engineering** attacks manipulate people into making security mistakes or giving away sensitive information. These attacks exploit human psychology rather than software vulnerabilities.

2.1 Phishing

Phishing is an attack where criminals send fraudulent communications (usually emails) that appear to come from a reputable source. The goal is to trick the victim into revealing sensitive information or clicking a malicious link.

Common characteristics of phishing emails:

- Appear to be from trusted organisations (banks, online shops, government)
- Create urgency ("Your account will be closed", "Unusual activity detected")
- Contain links to fake websites that look like the real thing
- Ask for personal information (passwords, card numbers)
- May contain spelling/grammar errors or suspicious sender addresses

Example scenario: A user receives an email appearing to be from their bank, stating there has been suspicious activity on their account. The email contains a link to "verify" their details. The link leads to a fake website that captures their login credentials.

2.2 Pretexting

Pretexting is when an attacker creates a fabricated scenario (pretext) to engage the victim and gain their trust. The attacker often impersonates someone in authority or someone who has a legitimate reason to need the information.

Examples of pretexting:

- Attacker phones a company pretending to be IT support, asking employees for their passwords to "fix" a problem
- Attacker poses as a bank employee and calls customers to "verify" account details
- Attacker impersonates a delivery driver to gain access to a building

2.3 Baiting

Baiting involves tempting victims with something desirable to trick them into compromising their security. The "bait" often takes the form of physical media (USB drives, CDs) or enticing downloads.

Examples of baiting:

- Leaving an infected USB drive labelled "Confidential" or "Payroll" in a public place, hoping someone will plug it into their computer
- Offering free software downloads that contain hidden malware
- Creating fake "you've won" messages that require clicking a link

2.4 Shoulder surfing

Shoulder surfing is the practice of spying on someone to obtain their private information. This can be done by looking over someone's shoulder as they enter a PIN, password, or other sensitive data.

Where shoulder surfing occurs:

- At cash machines (ATMs) — watching PIN entry
- In public places — observing people logging into accounts on laptops or phones
- At payment terminals — watching card numbers being entered

Prevention:

- Shield keypads when entering PINs
- Be aware of surroundings when entering sensitive information
- Use privacy screens on devices

2.5 Technical vulnerabilities

A **vulnerability** is a weakness in a computer system that can be exploited by attackers. Technical vulnerabilities exist in software, hardware, and networks.

Common vulnerabilities:

- **Unpatched software:** Software that has not been updated with security fixes
- **Weak passwords:** Simple, short, or commonly used passwords that are easy to guess
- **Default credentials:** Using manufacturer default usernames/passwords (e.g., "admin/admin")
- **Misconfigured systems:** Security settings not properly configured
- **Outdated systems:** Old operating systems or software no longer receiving security updates

> **Exam tip:** Social engineering attacks target **people**, not technology. The human is often the weakest link in security. When answering questions, emphasise that these attacks exploit trust, fear, or curiosity.

2.6 Why social engineering works

Social engineering exploits human psychology:

- **Trust:** We tend to trust authority figures or familiar brands
- **Fear:** Urgency creates panic ("Your account will be deleted")
- **Curiosity:** We want to see what's on that mysterious USB drive
- **Helpfulness:** We want to assist someone who seems to need help
- **Greed:** The promise of free items or prizes is tempting

2.7 Real-world examples of attacks

Understanding how attacks work in practice helps you recognise and avoid them:

Phishing example

Email from "Your Bank" with subject "Urgent: Suspicious Activity Detected"

- Email claims unusual activity on your account
- Link leads to a fake website that looks identical to the real bank
- User enters login details, which are captured by attackers
- Attackers now have access to the real bank account

Red flags: Generic greeting ("Dear Customer"), urgency, suspicious sender address, hovering over link shows wrong URL

2.8 The human factor in security

Security experts often say that humans are the weakest link in any security system. Even the most sophisticated technical protections can be bypassed if an attacker can trick a

person into giving them access.

Why humans are vulnerable:

- We are naturally inclined to trust and help others
- Under pressure, we make quick decisions without careful thought
- We may not recognise sophisticated attacks that appear legitimate
- Security procedures can feel inconvenient, leading to shortcuts
- Attackers continuously develop new techniques to exploit human nature

How organisations address human vulnerabilities:

- Regular security awareness training for all employees
- Simulated phishing exercises to test and educate staff
- Clear procedures for verifying unusual requests
- Creating a culture where reporting suspicious activity is encouraged
- Implementing technical controls that reduce reliance on human judgment

2.9 Attack and vulnerability diagram

```
┌──────────────────────────────────────────────────────────────────────────────────────────┐
│ SOCIAL ENGINEERING ATTACKS │
├──────────────────────────────────────────────────────────────────────────────────────────┤
│ │ │ ┌──────────────┐ ┌──────────────┐ ┌──────────────┐ ┌──────────────┐ │ │ │
PHISHING │ │ PRETEXTING │ │ BAITING │ │ SHOULDER │ │ │ │ │ │ │ │ │ SURFING
│ │ │ │ Fake emails │ │ Fabricated │ │ Tempting │ │ Observing │ │ │ │ and
websites│ │ scenarios │ │ victims with│ │ information │ │ │ │ │ │ │ "bait"
│ │ entry │ │ │ └──────┬───────┘ └──────┬───────┘ └──────┬───────┘
└──────┬───────┘ │ │ │ │ │ │ │
└──────────────┴──────────────┴──────────────┘ │ │ │ │ ▼ │ │
┌──────────────────────┐ │ │ │ EXPLOITS HUMAN │ │ │ │ PSYCHOLOGY │ │ │ │
(trust, fear, │ │ │ │ curiosity, greed) │ │ │ └──────────────────────┘ │ │
│
├──────────────────────────────────────────────────────────────────────────────────────────┤
│ TECHNICAL VULNERABILITIES │
├──────────────────────────────────────────────────────────────────────────────────────────┤
│ │ │ • Unpatched software • Weak passwords • Default credentials │ │ •
Outdated systems • Misconfigured settings │ │ │
└──────────────────────────────────────────────────────────────────────────────────────────┘
```

Worked Example 5 — Describing phishing

Question: Describe what is meant by a phishing attack. [2 marks]

Model answer:
A phishing attack involves sending fraudulent emails/messages that appear to be from a trusted source **(1)**.
The aim is to trick the victim into revealing sensitive information such as passwords or clicking on malicious links **(1)**.

Exam tip: For 2 marks, include: (1) the method (fake emails/websites), (2) the goal (steal information/credentials). An example can help but is not required unless asked.

Worked Example 6 – Explaining social engineering

Question: A company has experienced a security breach where an attacker phoned an employee pretending to be from IT support and obtained their password. State the name of this type of attack and explain why it was successful. [3 marks]

Model answer:
This is a **pretexting** / social engineering attack **(1)**.
It was successful because the attacker created a believable scenario / impersonated someone in authority **(1)**.
The employee trusted that the caller was genuinely from IT support and wanted to be helpful **(1)**.

Exam tip: Always link the attack name to the human element. Social engineering works because it exploits trust, not technical weaknesses.

Worked Example 7 – Identifying vulnerabilities

Question: A small business has not updated its software for two years. Explain one security risk this creates. [2 marks]

Model answer:
Unpatched software may contain known security vulnerabilities **(1)**.
Attackers can exploit these vulnerabilities to gain unauthorised access to the system or install malware **(1)**.

Exam tip: Software updates often include security patches that fix known vulnerabilities. Not updating leaves systems exposed to attacks that exploit these weaknesses.

Worked Example 8 – Explaining baiting

Question: A USB drive labelled "Staff Bonuses 2024" is found in a company car park. Explain how this could be used as a cyber attack. [3 marks]

Model answer:

This is a baiting attack **(1)**.
An employee may be curious and plug the USB drive into their work computer **(1)**.
The USB drive could contain malware that automatically installs and infects the company network when plugged in **(1)**.

Exam tip: Baiting exploits human curiosity. The "bait" is designed to be irresistible — labels like "Confidential", "Payroll", or "Bonuses" make people want to look.

3. Protection methods

Protecting against cyber threats requires a combination of technical measures and user awareness. No single protection is sufficient on its own — organisations use multiple layers of security (defence in depth).

3.1 Anti-malware software

Anti-malware software (including antivirus programs) protects computers by detecting, quarantining, and removing malicious software.

How anti-malware works:

- **Signature-based detection:** Compares files against a database of known malware signatures
- **Real-time scanning:** Monitors files as they are opened or downloaded
- **Scheduled scans:** Periodically scans the entire system for threats
- **Quarantine:** Isolates suspicious files so they cannot harm the system
- **Automatic updates:** Downloads new malware signatures to detect emerging threats

Limitations:

- Cannot detect brand-new malware (zero-day threats) not yet in the database
- Must be kept updated to remain effective
- May slow down system performance during scans

Anti-malware process flowchart

The 2024 exam asked students to draw a flowchart showing how antivirus software works. Here is the process:

```
┌──────────────┐ │ START │ └──────┬──────┘ │ ▼ ┌──────────────────────┐ │ Load
virus signature│ │ database │ └──────────┬──────────┘ │ ▼
┌──────────────────────┐ │ Scan target file │ │ (compare signatures)│
└──────────┬──────────┘ │ ▼ ┌──────────────┐ / \ / Virus \ NO / detected?
\────────┐ \ / │ \ / │ \──────────────/ │ │ YES │ ▼ │
┌──────────────────────┐ │ │ Quarantine/isolate │ │ │ infected file │ │
└──────────┬──────────┘ │ │ ▼ │ ┌──────────────────────┐ │ │ Delete or
repair │ │ │ the file │ │ └──────────┬──────────┘ │ │ │ ▼ ▼
┌──────────────────────┐ │ No further action │ │ required │
└──────────┬──────────┘ │ ▼ ┌──────────┐ │ END │ └──────────┘
```

3.2 Encryption

Encryption converts data into a coded format that can only be read by someone with the correct decryption key. Even if data is intercepted or stolen, it is unreadable without

the key.

Uses of encryption:

- **Data at rest:** Encrypting files stored on hard drives, USB drives, or cloud storage
- **Data in transit:** Encrypting data sent over networks (HTTPS, email encryption)
- **Full disk encryption:** Protecting entire hard drives so data is inaccessible if device is stolen

Example: Online banking uses encryption (HTTPS) to protect your login details and transaction data as it travels between your computer and the bank's servers.

> **Exam tip:** Encryption does not prevent data from being stolen — it prevents stolen data from being **read**. This is an important distinction.

3.3 Backup

A **backup** is a copy of data stored separately from the original. Regular backups protect against data loss from ransomware, accidental deletion, hardware failure, or natural disasters.

Backup best practices:

- **Regular schedule:** Back up frequently (daily for important data)
- **Separate storage:** Store backups in a different location (cloud, external drive, off-site)
- **Multiple copies:** Follow the 3-2-1 rule (3 copies, 2 different media, 1 off-site)
- **Test restores:** Regularly verify that backups can actually be restored

Protection against ransomware: If files are encrypted by ransomware, victims can restore from backup rather than paying the ransom — but only if backups are not also infected or connected to the infected system.

3.4 Acceptable Use Policies (AUPs)

An **Acceptable Use Policy (AUP)** is a document that defines how employees, students, or users are allowed to use an organisation's computer systems and networks.

What an AUP typically covers:

- Permitted and prohibited activities
- Password requirements and responsibility
- Rules about downloading software
- Email and internet usage guidelines
- Consequences for policy violations
- Data handling and confidentiality requirements

Why AUPs are important:

- Set clear expectations for user behaviour
- Reduce risk from accidental security breaches
- Provide legal protection for the organisation
- Educate users about security best practices

3.5 Software updates and patches

Software updates and **patches** fix known security vulnerabilities. Keeping software up to date is one of the most important security measures.

Why updates matter:

- Patches fix security flaws that attackers could exploit
- Many cyber attacks target known vulnerabilities in unpatched systems
- Automated updates ensure protection without user action

Types of updates:

- **Security patches:** Fix specific vulnerabilities as they are discovered
- **Feature updates:** Add new functionality (may also include security fixes)
- **Driver updates:** Update hardware device software
- **Firmware updates:** Update embedded device software

Risks of not updating:

- Systems remain vulnerable to known attacks
- Attackers actively scan for unpatched systems to exploit
- Major breaches have occurred because organisations failed to apply available patches

3.6 User awareness and training

Because many attacks target people rather than technology, **user awareness** is a critical protection. Even the best technical security can be bypassed by an uninformed user.

What users should know:

- How to recognise phishing emails and suspicious links
- The importance of strong, unique passwords
- Never sharing passwords or security credentials
- Being cautious about unknown USB drives or downloads
- Reporting suspicious activity to IT/security teams
- Following the organisation's security policies

Training methods:

- **Induction training:** Security basics for new employees
- **Regular refresher courses:** Keep security awareness current
- **Simulated attacks:** Test responses to fake phishing emails
- **Posters and reminders:** Visual prompts in the workplace
- **Incident reviews:** Learning from actual security events

3.7 Strong passwords

Strong passwords are a fundamental security measure. Weak passwords are easily guessed or cracked using automated tools.

Characteristics of strong passwords

- **Length:** At least 8—12 characters (longer is better)
- **Complexity:** Mix of uppercase, lowercase, numbers, and symbols
- **Unpredictable:** Not based on dictionary words, names, or personal information
- **Unique:** Different password for each account

Password weaknesses to avoid

- Common words: "password", "123456", "qwerty"
- Personal information: names, birthdays, pet names
- Simple patterns: "abc123", "Password1"
- Reusing the same password across multiple sites

3.8 Protection methods diagram

```
┌──────────────────────────────────────────────────────────────────────────────────────┐
│ LAYERS OF PROTECTION │
├──────────────────────────────────────────────────────────────────────────────────────┤
│ │ │
│ ┌──────────────────────────────────────────────────────────────────────────────┐ │ │
│ │ USER AWARENESS & POLICIES │ │ │ │ • Acceptable Use Policies • Security
training • Strong passwords │ │ │
│ └──────────────────────────────────────────────────────────────────────────────┘ │ │
│ │ │
│ ┌──────────────────────────────────────────────────────────────────────────────┐ │ │
│ │ SOFTWARE PROTECTION │ │ │ │ • Anti-malware • Software updates/patches •
Encryption │ │ │
│ └──────────────────────────────────────────────────────────────────────────────┘ │ │
│ │ │
│ ┌──────────────────────────────────────────────────────────────────────────────┐ │ │
│ │ DATA PROTECTION │ │ │ │ • Regular backups • Encryption at rest • Access
controls │ │ │
│ └──────────────────────────────────────────────────────────────────────────────┘ │ │
│ │ Defence in depth: Multiple layers so if one fails, others still protect
│ │ │
└──────────────────────────────────────────────────────────────────────────────────────┘
```

Worked Example 9 — Explaining anti-malware protection

Question: Explain how anti-malware software protects a computer system. [3 marks]

Model answer:
Anti-malware software scans files and compares them against a database of known malware signatures **(1)**.
If a threat is detected, the malware is quarantined/isolated so it cannot damage the system **(1)**.
The software can then delete/remove the malware or alert the user to take action **(1)**.

> **Exam tip:** Follow the logical sequence: detect → quarantine → remove. For full marks, explain each stage of the process.

Worked Example 10 — Describing encryption benefits

Question: A company stores customer data on laptops used by employees. Explain one benefit of encrypting this data. [2 marks]

Model answer:
If a laptop is lost or stolen, the data would be unreadable without the decryption key **(1)**.
This protects customer data from unauthorised access and helps the company comply with data protection laws **(1)**.

Exam tip: Always link the protection to the specific scenario. Here, the risk is laptops being lost/stolen, so the benefit is that encrypted data is useless to thieves.

Worked Example 11 – Discussing backup importance

Question: A hospital has been infected with ransomware that has encrypted all patient records. Discuss how having regular backups could help in this situation. [4 marks]

Model answer:
Regular backups mean the hospital has copies of patient records stored separately **(1)**.
The hospital can restore the patient records from the backup without needing the decryption key **(1)**.
This means they do not need to pay the ransom to the attackers **(1)**.
However, this only works if the backups were stored offline/separately and were not also encrypted by the ransomware **(1)**.

Exam tip: For "discuss" questions, consider both positives and limitations. Backups are effective against ransomware, but only if stored properly (offline, separate location).

Worked Example 12 – Evaluating protection methods

Question: A school is implementing security measures to protect against cyber threats. Evaluate the effectiveness of using an Acceptable Use Policy (AUP) as a protection method. [4 marks]

Model answer:
Advantages:
An AUP sets clear rules about acceptable behaviour, such as not downloading unauthorised software or clicking unknown links **(1)**.
It helps educate users about security risks and their responsibilities, reducing accidental breaches **(1)**.
Limitations:
An AUP relies on users following the rules — it cannot technically prevent someone from breaking them **(1)**.
It does not protect against external attacks or technical vulnerabilities — it must be combined with other measures like anti-malware and encryption **(1)**.

Exam tip: "Evaluate" requires you to weigh up advantages and limitations. No single protection is perfect — always consider what it does well and what it cannot do.

Worked examples summary

This section summarises the 12 worked examples covered in this topic, organised by difficulty level and question type. Use these examples to practise exam technique and understand what examiners are looking for.

Exam strategy for cyber security questions

Cyber security questions in Paper 1 typically follow predictable patterns. Understanding these patterns helps you structure effective answers:

For "Define" questions (1–2 marks)

- Give a concise, accurate definition
- Include key distinguishing features
- Do not waste time on examples unless asked

For "Describe" questions (2–3 marks)

- Set out the main characteristics or process
- Use specific terminology from the specification
- One developed point per mark available

For "Explain" questions (2–4 marks)

- Give reasons and make relationships clear
- Link cause and effect explicitly
- Apply to the scenario given in the question

For "Discuss/Evaluate" questions (4–6 marks)

- Consider multiple viewpoints or aspects
- Weigh up advantages and limitations
- Reach a reasoned conclusion where appropriate

Example distribution by section

Example	Topic	Question type	Marks	Key skill
1	Malware definition	Define	1	Recall key definition
2	Malware types	State	2	Identify examples
3	Virus spread	Describe	2	Explain process
4	Virus vs worm	Compare	2	Identify differences
5	Phishing	Describe	2	Explain attack method
6	Social engineering	Explain	3	Apply to scenario
7	Vulnerabilities	Explain	2	Link cause to risk
8	Baiting attack	Explain	3	Apply to scenario
9	Anti-malware	Explain	3	Describe process
10	Encryption	Explain	2	Apply benefit to scenario
11	Backup	Discuss	4	Extended reasoning
12	AUP evaluation	Evaluate	4	Weigh advantages/limitations

Exam command words for this topic

- **Define:** State the meaning of a term
- **State:** Give a brief answer without explanation
- **Describe:** Set out characteristics or features
- **Explain:** Give reasons or make relationships clear
- **Compare:** Identify similarities and/or differences
- **Discuss:** Consider different aspects or viewpoints
- **Evaluate:** Judge the worth or importance, considering different points

Quick reference

Use these tables for quick revision before exams. The definitions are written in mark-scheme style — memorising these exact phrasings will help you score full marks on definition and identification questions.

Key terms and definitions

Term	Definition (mark-scheme style)
Malware	Malicious software designed to damage, disrupt, or gain unauthorised access to a computer system
Virus	Malware that attaches to a host file and requires user action to spread
Worm	Self-replicating malware that spreads automatically across networks without user action
Trojan	Malware disguised as legitimate software; does not self-replicate
Ransomware	Malware that encrypts files and demands payment for the decryption key
Keylogger	Software or hardware that records keystrokes to capture sensitive information
Phishing	Fraudulent attempt to obtain sensitive information by pretending to be a trusted source
Social engineering	Manipulating people into revealing confidential information or performing actions that compromise security
Pretexting	Creating a fabricated scenario to engage a victim and gain their trust
Baiting	Tempting victims with something desirable (often infected media) to compromise security
Shoulder surfing	Observing someone to obtain their private information (e.g., watching PIN entry)
Vulnerability	A weakness in a system that can be exploited by attackers
Encryption	Converting data into a coded format that requires a key to decrypt
Backup	A copy of data stored separately from the original to protect against data loss
AUP	Acceptable Use Policy — rules defining how systems and data should be used

Threats and protections quick match

Threat	Primary protection(s)
Viruses, worms, Trojans	Anti-malware software, software updates
Ransomware	Backups, anti-malware, user awareness
Keyloggers	Anti-malware, physical security checks

Threat	Primary protection(s)
Phishing	User training, email filtering, AUP
Social engineering	User awareness training, AUP, verification procedures
Data theft	Encryption, access controls
Unpatched vulnerabilities	Software updates, patch management
Weak passwords	Password policies, multi-factor authentication

Malware comparison

Feature	Virus	Worm	Trojan
Needs host file	Yes	No	No (is the file)
Self-replicating	Yes (with host)	Yes (independently)	No
User action needed	Yes	No	Yes (installation)
Main spread method	Infected files	Network vulnerabilities	Social engineering

Typical pitfalls

Pitfall 1 — Confusing virus and worm.
Wrong: "A worm is just another name for a virus."
Right: Viruses need a host file and user action; worms are **self-replicating** and spread automatically over networks.

Pitfall 2 — Thinking Trojans self-replicate.
Wrong: "A Trojan spreads by copying itself to other computers."
Right: Trojans do **not** self-replicate. They rely on users downloading and installing them, thinking they are legitimate software.

Pitfall 3 — Incomplete phishing definition.
Wrong: "Phishing is when someone steals your data."
Right: Phishing specifically involves **fraudulent communications** (emails/websites) that **appear to be from trusted sources** to trick users into revealing information.

Pitfall 4 — Thinking encryption prevents theft.
Wrong: "Encryption stops hackers from stealing data."
Right: Encryption does not prevent data from being stolen — it prevents stolen data from being **read**. The data is still taken, but it is useless without the decryption key.

Pitfall 5 — Forgetting backups need to be separate.
Wrong: "Having a backup on the same computer protects against ransomware."
Right: Backups must be stored **separately** (offline, different location) — otherwise ransomware can encrypt the backup too.

Pitfall 6 — Thinking anti-malware catches everything.
Wrong: "Anti-malware software protects against all threats."
Right: Anti-malware cannot detect brand-new threats (zero-day attacks) and must be regularly updated. It also does not protect against social engineering.

Pitfall 7 — Confusing social engineering with hacking.
Wrong: "Social engineering is when hackers break into systems using technical skills."
Right: Social engineering exploits **people**, not technology. It manipulates human psychology (trust, fear, curiosity) rather than technical vulnerabilities.

Pitfall 8 — Vague answers about AUPs.
Wrong: "An AUP protects the computer."
Right: An AUP sets **rules for user behaviour** — it educates users, sets expectations, and provides a framework for enforcement. It works through **people**, not technology.

Pitfall 9 — Not linking threat to appropriate protection.
Wrong: "Anti-malware protects against shoulder surfing."
Right: Match protections to threats: shoulder surfing is prevented by **user awareness** and physical precautions (shielding keypads), not software.

Pitfall 10 — Generic answers without context.
Wrong: "Encryption is good because it protects data."
Right: Link to the scenario: "If the laptop is stolen, encrypted data would be unreadable without the decryption key, protecting customer information."

Assessment Hub | Long-Answer | Notes Index

Williams Physics Education — over **1,100,000+ marks** of exam-aligned content and **4,200+ auto-marked assessments** across 67 qualifications at GCSE, A-Level, AP & Professional

Qualifications. Free to use, no login required.
About & Contact • Privacy • Terms • Accessibility • Copyright • DMCA • YouTube
WPE is free for everyone. If our resources help you or your students, you can support the project here.
© 2026 Williams Physics Education. All rights reserved.